From Fleet to Firmware:
Bringing AI-Native Security to Open Hardware with Project Equilibrium

Andrés Lagar-Cavilla
Distinguished Engineer

Google Cloud

OCP Global Summit · October 2026

Accelerating Defense: Agentic SDLC

Key insights from Black Hat USA 2026 on securing the software development lifecycle

AUGUST 7, 2026

Balancing the Odds

The first and foremost step to protect organizations against emerging agentic adversaries in software security.

error_outline **HuggingFace incident debrief, Aug 7th 2026**



"The challenge is that we need a similar acceleration of defense, today we see fully automated offense as possible we have no such existence proof for full automation of core defensive loops and cycles and behavior. We believe it's vital at this moment to begini accelerating defense and automate SDLC"

Google

Turn a crisis into an opportunity
Achieve the “new equilibrium” in the way we work

AGENTIC SECURITY SCANS

The Limitations of One-Off Scans

By now it is normal to hear about agentic scans using frontier models like Mythos, Astra or Argon

data_object

01

Context Demand

A full codebase scan requires substantial context

auto_delete

02

High Volume Slop

Raise your hand if you have had to work through all the output of one scan.

filter_alt_off

03

Low Relevance

A lot of well meaning findings that are not relevant

fact_check

04

Triage Load

One-off scans lead to a substantial amount of triage after the act

groups

05

Team Activation

Then you have to activate teams to fix all these issues

AGENTIC SECURITY SCANS

Envision Pervasive, Always-On Scanning

Every code change, increment & contribution scanned by specialized agents — separate from code-authoring agents.

center_focus_strong

01

Precise: No Slop

High signal-to-noise ratio with strict, noise-free analysis.

psychology

02

Context Aware

Deep understanding of project threat models & architecture.

fact_check

03

Auto Triage

Performs initial triage and filtering for you automatically.

build_circle

04

Fix Generation

Proactively generates actionable fix patches for findings.

bolt

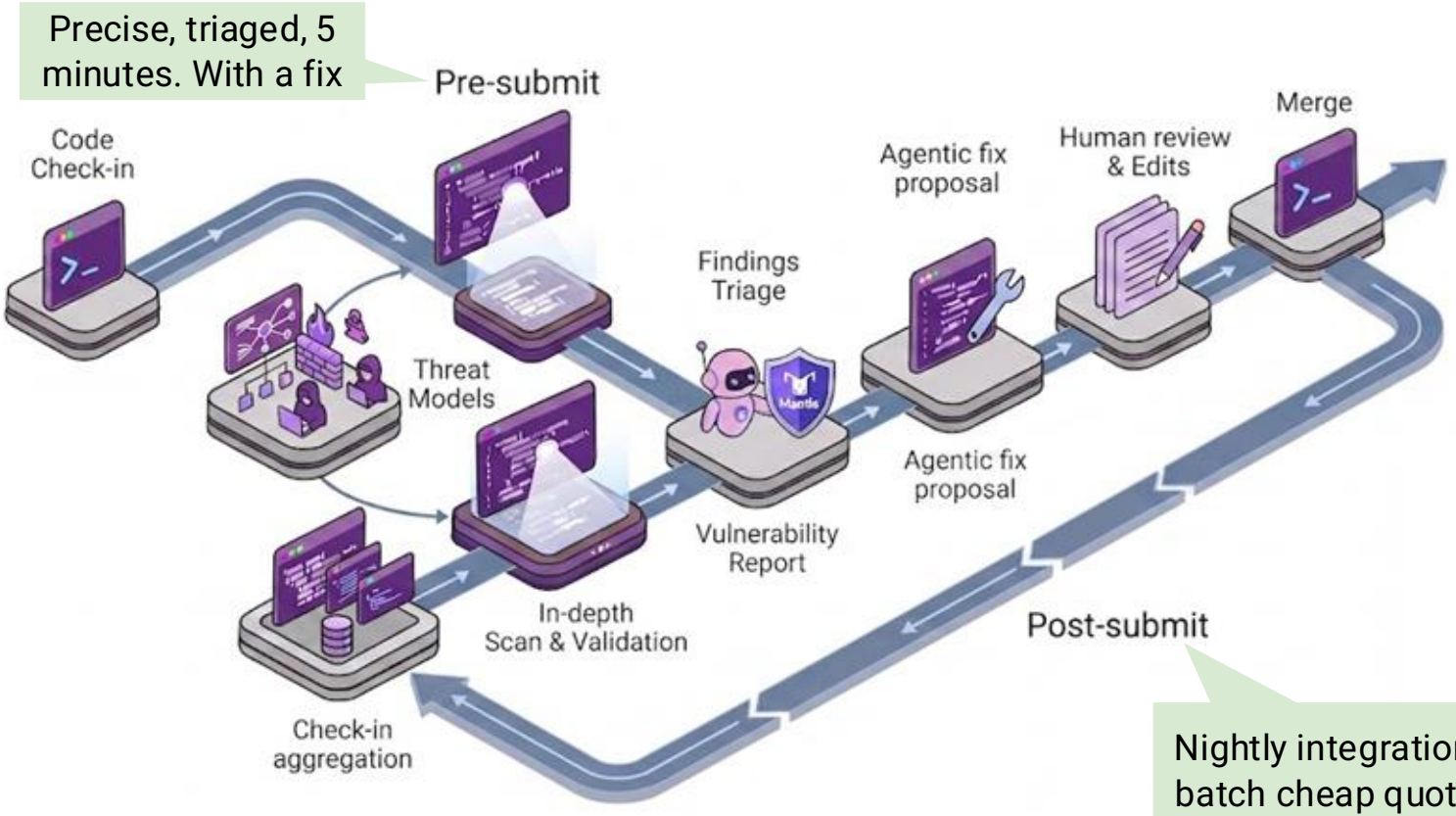
05

Interactive Speed

Runs at near-interactive speeds right as engineers merge code.

Mantis: Our agentic scan harness. Open source — ready for deployment.

Pervasive, Always-On Scanning at Google



Google

Project Equilibrium: Value Delivered

Mitigation Volume

~1,250

Bugs Fixed

bug_report

High-Severity Security Defects

Based on actual bugs successfully mitigated, scaling security resolution programmatically across the production fleet.

ed_use

196 **vulnerabilities *prevented* in an average month**
with partial onboarding

Google

Mantis Presubmit Check Onboarding & Efficacy

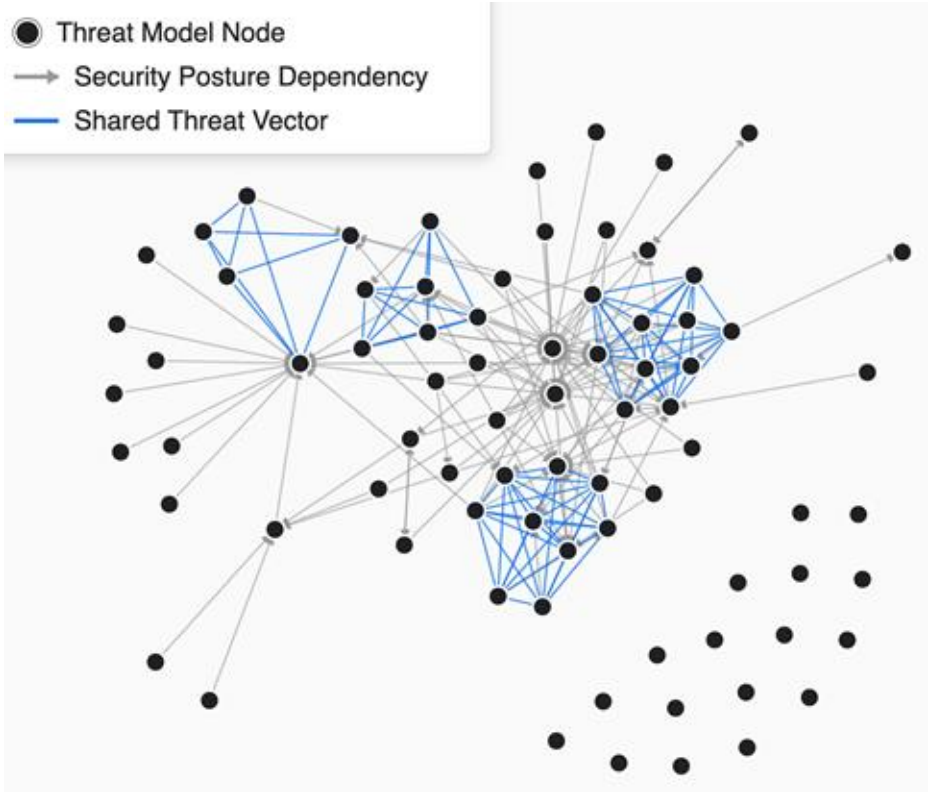


25K
Total Scans

100+
Threat Models

Google

Teaching Threat Models to Agents: Scaling Out Through Chaining



This graph is based on actual Google threat models committed into Mantis

Cascading Posture Management

What: A's security baseline relies on B. An incident or patch in B forces A to upgrade its security posture.

Example: `diskfwtool` calls `storage_firmware` to verify eFuse rollback counters. If flawed, the former must be hardened.

Mantis - Triage Agent Integration: High-Precision, High-Throughput Automated Triage

Accuracy & Quality

91.1%

Precision across all languages

77.2% Recall | **83.6%** F1-Score
Tested on 355-CL benchmark

Near-zero false alarms on highly complex datasets significantly minimize developer disruption during critical presubmit checks.

Speed & Efficiency

5.8s
Avg / Bug

~100s
Avg / CL

Delivers **10.3 bugs/min**
Under 10-worker concurrency

CL-level analysis takes ~100s due to preprocessing overhead under single worker optimization, comfortably fitting inside 5-min presubmit budgets.

Intelligence Engine

Rich RAG

Hybrid Call Graph Traversal

Smart Context: Parses local directory code into abstract syntax trees (ASTs) on-the-fly, enriched by team CL patterns.

Hybrid Graph: Blends real-time workspace parsing with Google's Kythe code-graph APIs.

Monorepo Scale: Zero-config triage for C++, Java, Go, and enterprise codebases.

Google

Mantis Contextualized: Integrating with a BugFixAgent

Synergies with CodeMender

Bug Fix Agent & Presubmit

To bridge the gap between discovery and automated fixing, Mantis presubmit findings feed directly into agentic remediation engines.

Bug Fix Agent (BFA)

Achieves a **78.4%** success rate via local CLI, providing critical immediate fixes for TPU firmware and core systems.

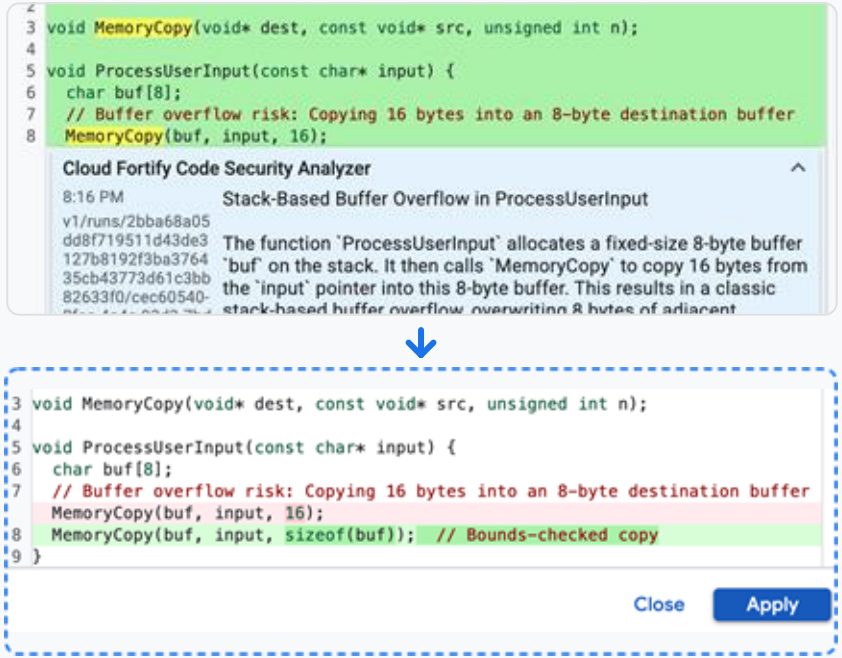
Presubmit Integration

Validated Mantis vulnerabilities route directly into BFA to generate verified patches at scale.

The Target Model

Increase patching success rate to **90%+** by integrating presubmit-time self-reviewing loops and offline self-improvement.

Automated Code Remediation Workflow



AGENTIC SECURITY SCANS

Google's Agentic SDLC: Pervasive, Always-On Scanning

Every code change, increment & contribution scanned by specialized agents — separate from code-authoring agents.

center_focus_strong

01

Precise: No Slop

High signal-to-noise ratio with strict, noise-free analysis.

psychology

02

Context Aware

Deep understanding of project threat models & architecture.

fact_check

03

Auto Triage

Performs initial triage and filtering for you automatically.

build_circle

04

Fix Generation

Proactively generates actionable fix patches for findings.

bolt

05

Interactive Speed

Runs at presubmit of each code change in <5 minutes

nights_stay

06

Nightly Integration

Regression scanning run overnight across the whole batch of changes.

Mantis: Our agentic scan harness. Open source at https://github.com/google/mantis— ready for deployment.